



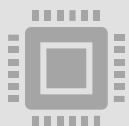
基於對抗式攻擊與情資平台之 HTTP/3 加密流量自動化安全防 禦框架

指導教授：王智弘教授

組員資訊：1122931 莊博宇

1122930 闕帝軒

研究動機



HTTP/3 帶來的防禦真空：HTTP/3 (基於 QUIC 協定) 已成為新世代傳輸標準，但其基於 UDP 且強制 TLS 1.3 加密的特性，導致傳統基於特徵碼 (Signature-based) 與深度封包檢測 (DPI) 的防火牆完全失效。



對抗式規避技術 (Adversarial Evasion)：惡意攻擊者透過封包切割、時序干擾等手法偽裝成正常流量，改變統計特徵以騙過傳統模型。



標記成本與告警疲勞：真實網路環境中攻擊手法變幻莫測，要蒐集並標記大量的最新攻擊樣本是不切實際的。面對層出不窮的警告，資安人員往往面臨告警疲勞。

文獻/既有系統服務探討

加密流量分析與 HTTP/3 (QUIC) 的挑戰

- QUIC 協議不僅加密了Payload，還對連線握手 (Handshake) 封包進行了混淆，導致傳統依賴明文 (如 SNI) 的深度封包檢測失去效用。
- 文獻指出，目前的技術正從人工特徵工程轉向自動特徵提取。然而，若過度依賴握手階段的特徵，將導致分類模型在真實環境中快速失效。
- 在加密流量環境中，獲取大規模且準確的標記數據極為困難且成本高昂。這使得依賴大量完美標記數據的傳統監督式學習，難以直接應用於真實的資安維運中。

[4] J. Li, L. Zhou, H. Li, L. Yan and H. Zhu, Dynamic Traffic Feature Camouflaging via Generative Adversarial Networks

[5] J. Luxemburk, K. Hynek and T. Čejka, Encrypted Traffic Classification: The QUIC Case

文獻/既有系統服務探討

非監督式學習對抗未知威脅

- 攻擊者已開始利用生成對抗網路 (如 FlowGAN) 進行動態流量特徵偽裝，改變封包大小、時間間隔等高維統計分佈，以規避傳統的流量分析系統。
- 傳統異常檢測高度依賴預先存在的攻擊特徵知識，無法有效應對未知的零時差攻擊。
- 導入非監督式深度學習，模型僅需學習正常流量的分佈；當遭遇經過偽裝、時序行為偏離正常基準的對抗式攻擊流量時，便會產生高重構誤差 (Reconstruction Error) 而被成功捕捉。這種架構不僅減少了對歷史特徵的依賴，也能縮短模型訓練時間。

[2] W. Lim, K. S. C. Yong, B. T. Lau, and C. C. L. Tan, Future of Generative Adversarial Networks (GAN) for Anomaly Detection in Network Security: A Review

[4] J. Li, L. Zhou, H. Li, L. Yan and H. Zhu, Dynamic Traffic Feature Camouflaging via Generative Adversarial Networks

文獻/既有系統服務探討

情資平台與 SOAR 的自動化協作

- 安全維運中心的分析師常面臨資訊過載與告警疲勞。透過 SOAR 自動化收集日誌與標準化數據，能有效釋放分析師的時間。
- 將 AI 與 SOAR 整合，能根據上下文與嚴重性對警報進行智慧排序，減少誤報。
- 針對低風險或模型已判定為惡意的異常行為，AI 驅動的 SOAR 可自動發送防火牆阻斷規則並執行處置，顯著縮短平均回應時間 (MTTR)。同時，結合 MISP 情資平台動態生成威脅指標 (IoC)，達成持續學習的防禦生態。

[6] N. B. Kilaru, S. K. M. Cheemakurthi and V. Gunnam, SOAR Solutions in PCI Compliance: Orchestrating Incident Response for Regulatory Security

[7] S. Subudhi, Effectiveness of AI/ML in SOAR (Security Automation and Orchestration) Platforms

專題方法與系統開發相關技術

本系統採用混合式防禦架構，結合威脅情資、半監督式深度學習與 SOAR 機制。我們將使用 Ubuntu 作為操作系統，並以 Python (aioquic) 搭配 Python (Scapy) 進行虛擬環境中的封包側錄與特徵收集。深度學習模型擬使用 PyTorch 框架開發，威脅情資平台則透過 Docker 容器化部署 MISP。



提取有效指紋：在不解密的情況下，提取 HTTP/3 加密流量的有效特徵 (如封包長度、到達時間間隔)。

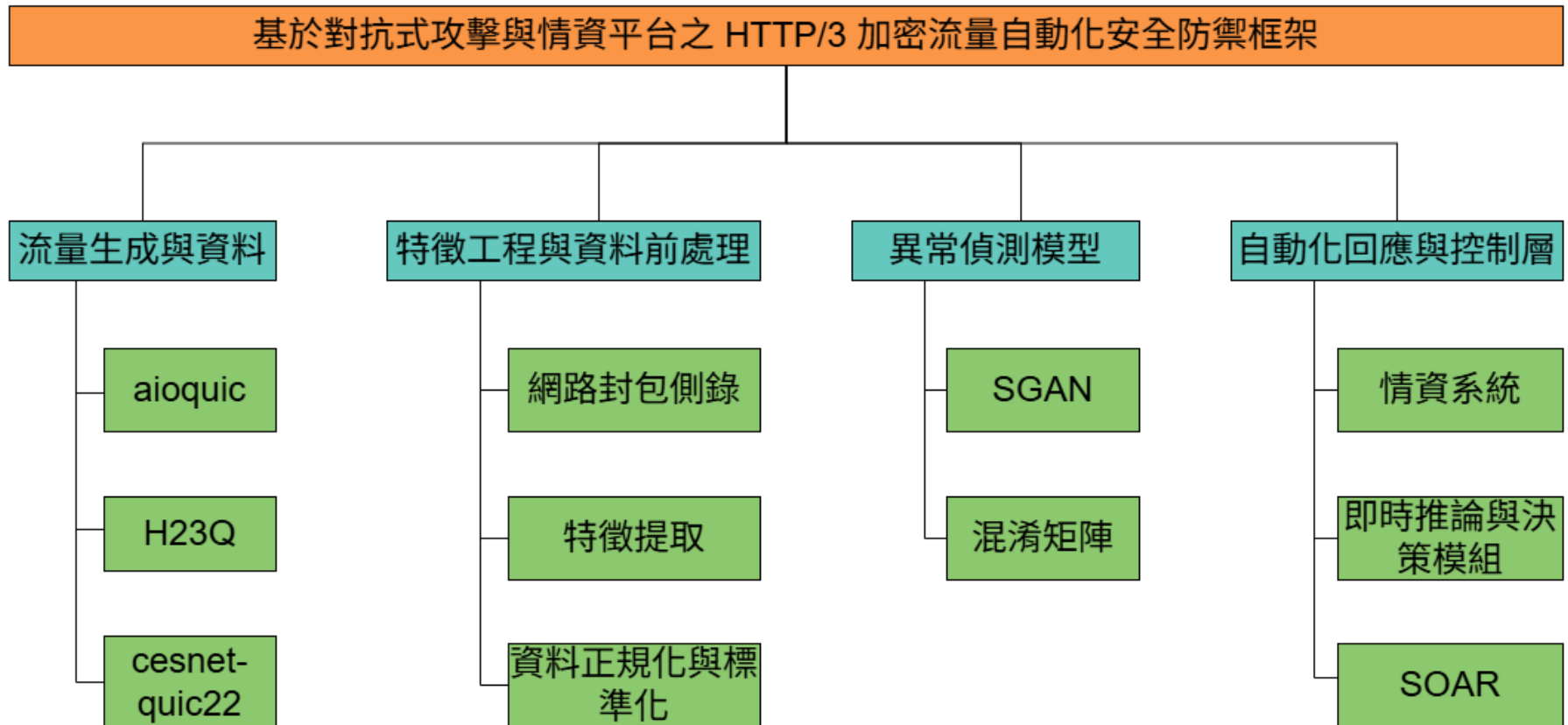


半監督式學習防禦未知威脅：在缺乏惡意標記數據的環境下，利用深度學習進行半監督式學習，實現對零時差攻擊的偵測。



情資與自動化閉環：整合 MISP 威脅情資平台與資安協作自動化應變 (SOAR) 機制，實現異常自動化回應。

專題方法與系統開發相關技術

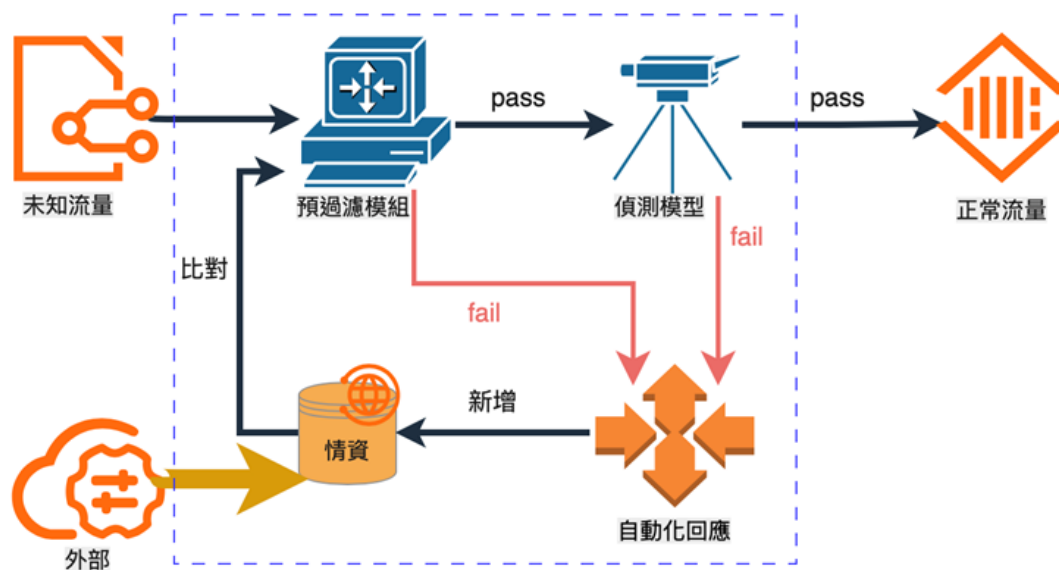


[9] E. Chatzoglou, V. Kouliaridis, G. Kambourakis, G. Karopoulos, and S. Gritzalis, A hands-on gaze on HTTP/3 security through the lens of HTTP/2 and a public dataset

[10] J. Luxemburk, K. Hynek, T. Čejka, A. Lukačovič, and P. Šiška, CESNET-QUIC22: A large one-month QUIC network traffic dataset from backbone lines

專題方法與系統開發相關技術

- **預過濾模組**：提取來源 IP，即時比對自建的 MISP 情資平台。若命中黑名單直接阻斷，大幅降低後端 AI 運算負載。
- **異常偵測模型**：針對未知流量提取特徵並輸入模型。當遭遇攻擊特徵時將產生高重構誤差 (Reconstruction Error)，藉此判定為異常。
- **自動化回應模組**：判定為惡意後，觸發控制器透過 Linux iptables 發送阻斷規則，並將新威脅指標 (IoC) 回寫至 MISP。



已有成果

資料集

training set	以標記	未標記
正常流量	268453	301852
惡意流量	207454	278912
testing set		
正常流量	544463	
惡意流量	176126	

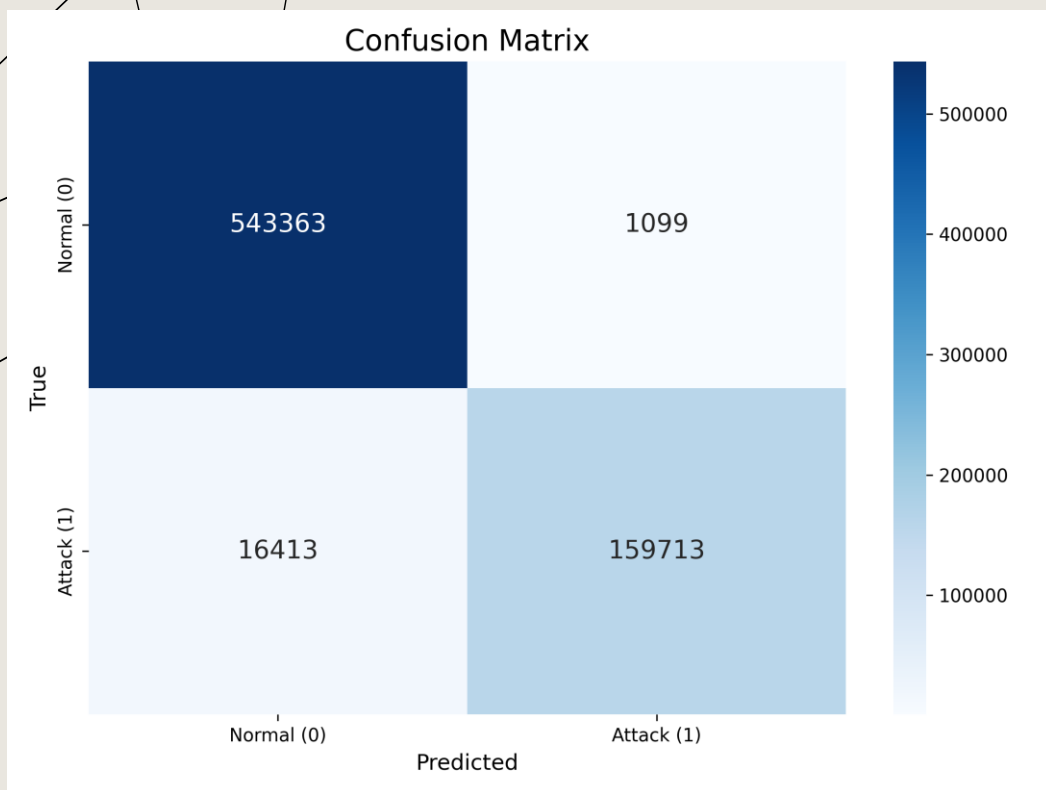
特徵工程與資料正規化

Direction	
Packet_Length	MinMax [-1, 1]
IAT(ms)	Log1p + MinMax [-1, 1]
Burst_Count	MinMax [-1, 1]
Burst_Bytes	Log1p + MinMax [-1, 1]
Flow_Up_Bytes	Log1p + MinMax [-1, 1]
Flow_Down_Bytes	Log1p + MinMax [-1, 1]
Up_Down_Ratio	Log1p + MinMax [-1, 1]

Log1p : $x' = \log(x + 1)$

Min-Max [-1, 1] : $x_{scaled} = 2 \times \frac{x' - x'_{min}}{x'_{max} - x'_{min}} - 1$

已有成果



報告

	precision	recall	f1-score	support
Normal (0)	0.97	1.00	0.98	544462
Attack (1)	0.99	0.91	0.95	176126
accuracy			0.98	720588
macro avg	0.98	0.95	0.97	720588
weighted avg	0.98	0.98	0.98	720588



未來工作

- 針對資料集在進行優化以及增加
- 完成 SGAN 模型的參數調校與完整數據集訓練
- 建置MISP情資系統
- 開發 SOAR 自動化腳本

預計參加的比賽項目

- 115資工系計算機專題競賽
- 全國創意與智慧科技競賽 --人工智慧組
- 大專校院資訊應用服務創新競賽

參與人員分工與時數分配

莊博宇	模型生成與系統整合	50%
闕帝軒	資料收集與數據採集	50%



結論

本計畫針對協定典範轉移帶來的防禦真空，提出了一套整合威脅情資、半監督式深度學習與資安事件自動化回應的混合式防禦架構。透過自建的高擬真攻防實驗場域，我們預期能有效驗證系統在面對對抗式攻擊時的強健性，並實現從偵測到阻斷的完全自動化，並將為後量子時代的加密網路安全提前部署，設計出具前瞻性且能實際落地應用於資安維運的解決方案。

參考文獻

- [1] M. Shen, K. Ye, X. Liu, L. Zhu, J. Kang, S. YU, “Machine Learning-Powered Encrypted Network Traffic Analysis: A Comprehensive Survey,” in IEEE Communications Surveys & Tutorials, vol. 25, no. 1, pp. 791-824, Firstquarter 2023.
- [2] W. Lim, K. S. C. Yong, B. T. Lau, and C. C. L. Tan. “Future of Generative Adversarial Networks (GAN) for Anomaly Detection in Network Security: A Review,” Computers & Security, vol. 139, Apr. 2024, Art. no. 103733.
- [3] A. S. Iliyasu and H. Deng, “Semi-Supervised Encrypted Traffic Classification with Deep Convolutional Generative Adversarial Networks,” in IEEE Access, vol. 8, pp. 118-126, 2020.
- [4] J. Li, L. Zhou, H. Li, L. Yan and H. Zhu, “Dynamic Traffic Feature Camouflaging via Generative Adversarial Networks,” 2019 IEEE Conference on Communications and Network Security (CNS), Washington, DC, USA, 2019, pp. 268-276.
- [5] J. Luxemburk, K. Hynek and T. Čejka, “Encrypted Traffic Classification: The QUIC Case,” 2023 7th Network Traffic Measurement and Analysis Conference (TMA), Naples, Italy, 2023, pp. 1-10
- [6] N. B. Kilaru, S. K. M. Cheemakurthi and V. Gunnam, “SOAR Solutions in PCI Compliance: Orchestrating Incident Response for Regulatory Security,” ESP Journal of Engineering & Technology Advancements, vol. 1, Issue 2, pp. 78-84, 2021.
- [7] S. Subudhi, “Effectiveness of AI/ML in SOAR (Security Automation and Orchestration) Platforms,” International Journal of Science and Research (IJSR), volume 13, issue 8, pp. 201-206, Aug. 2024.
- [8] J. Iyengar, M. Thomson, “QUIC: A UDP-Based Multiplexed and Secure Transport,” IETF, FEB. 2022.
- [9] E. Chatzoglou, V. Kouliaridis, G. Kambourakis, G. Karopoulos, and S. Gritzalis, “A hands-on gaze on HTTP/3 security through the lens of HTTP/2 and a public dataset,” Comput. Secur., vol. 125, Feb. 2023, Art. no. 103051.
- [10] J. Luxemburk, K. Hynek, T. Čejka, A. Lukačovič, and P. Šiška, “CESNET-QUIC22: A large one-month QUIC network traffic dataset from backbone lines,” Data Brief, vol. 46, Feb. 2023, Art. no. 108888.

